Threat Brief: The Axios Supply Chain Attack

AXIOS



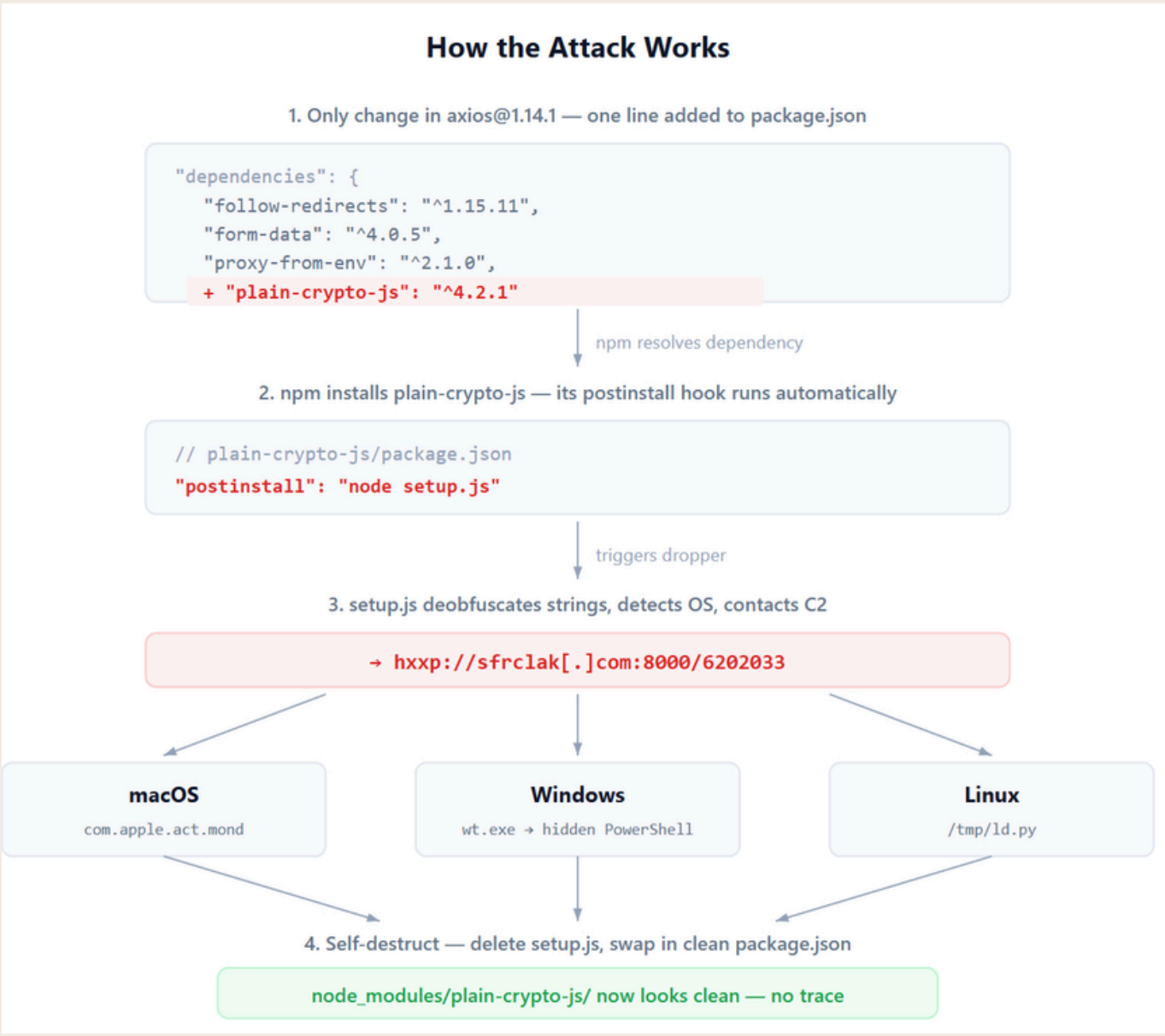
Memori CTI

What Happened?

On March 30-31, 2026, a maintainer account for the Axios project was compromised. Instead of altering the main Axios code directly, the attackers took a stealthier approach. They released Axios versions 1.14.1 and 0.30.4, which secretly included a fake, malicious dependency (sub-package) called plain-crypto-js.

When developers installed or updated to these new Axios versions, the fake package automatically downloaded and ran in the background.

What Does the Malware Do?



This malicious package acts as a dropper for a Remote Access Trojan (RAT). A RAT is a type of malware that allows attackers to connect to and take full remote control of a victim's machine. This specific threat is highly versatile, designed to target Windows, macOS, and Linux systems alike. Furthermore, once it executes, the malware attempts to delete its own tracks, making post-incident detection much more difficult.

Is the Threat Over?

The NPM security team noticed the anomaly and removed the malicious versions within approximately three hours, neutralizing the fake package. However, anyone who updated their systems or ran automated installations during that brief window remains at risk.

2026-03-31 ~03:15	npm unpublishes `axios@1.14.1` and `axios@0.30.4`. Both versions are removed from the registry and the `latest` dist-tag reverts to `1.14.0`. `axios@1.14.1` had been live for approximately 2 hours 53 minutes; `axios@0.30.4` for approximately 2 hours 15 minutes. Timestamp is inferred from the axios registry document's `modified` field (03:15:30Z) — npm does not expose a dedicated per-version unpublish timestamp in its public API.
2026-03-31 03:25	npm initiates a security hold on `plain-crypto-js`, beginning the process of replacing the malicious package with an npm security-holder stub.
2026-03-31 04:26	npm publishes the security-holder stub `plain-crypto-js@0.0.1-security.0` under the `npm@npmjs.com` account, formally replacing the malicious package on the registry. `plain-crypto-js@4.2.1` had been live for approximately 4 hours 27 minutes. Attempting to install any version of `plain-crypto-js` now returns the security notice.

How to Check Your Systems

If you use Axios in your environment, you can take these simple steps to ensure you are not compromised:

- Check for the malicious Axios versions.
- Check for RAT artifacts: "/Library/Caches/com.apple.act.mond" (macOS), "%PROGRAMDATA%\wt.exe" (Windows), and "/tmp/ld.py" (Linux).
- Downgrade to Axios versions 1.14.0 or 0.30.3.
- Remove "plain-crypto-js" from the "node_modules" directory.
- If RAT artifacts are detected, assume compromise and rotate all credentials on the system.
- Audit CI/CD pipelines for runs that installed the affected versions.
- Block egress traffic to the command-and-control domain ("sfrclak[.]com")